SENTINEL · ESSECKATHON TRACK 01 · FINTECH SECURITY · EQUIPE 2

Defense sheet

Un garde devant tout paiement d'agent IA : il verifie l'autorite et l'intention, delivre un visa on-chain si OK, refuse et flague si c'est une arnaque, escalade a un humain en cas de doute. Chaque decision est une preuve inviolable sur Avalanche.

SentinelL1 Live | chainId 99999 | ERC-8004 + x402 | 2026-10-11

Scenario de menace traite

« a low-privilege agent, fed a booby-trapped document, tells a financial agent to execute a payment. Without authority-chain checks, it goes through. » (Track 01, probleme 2)

Un agent peu privilegie, nourri d'un document piege, ordonne un paiement a un agent financier. Sans verification de la chaine d'autorite, il passe. Cas reel Scamlexity : un agent de shopping achete sur un faux site et livre les donnees de paiement.

Vecteurs couverts : injection indirecte (HTML cache, PDF, mail), tool poisoning (MCP), confusion d'autorite, address poisoning, tresorerie migree, encodage (base64 / hex / url / ROT13), homoglyphes, unicode invisible, depassement de mandat, contrepartie frauduleuse (domaine neuf, marque sosie, honeypot).

Fonctions NIST CSF couvertes

Identify	Mandats et autorites resolus cote serveur, jamais declares par l'agent.
Protect	Visa on-chain a usage unique, GuardedVault fail-closed (pas de visa = revert).
Detect	7 couches de signaux + fusion Claude sur l'intention et l'injection.
Respond	Block + flag de l'adresse + escalade humaine, incident DORA ouvert au refus.
Recover	Trace on-chain rejouable, registre de menaces partage et reutilisable.

ATT&CK / ATLAS & risques OWASP

OWASP ASI03 Compromission d'autorite : un agent peu privilegie declenche un paiement qu'il ne peut pas ordonner. Pare par la verification de la chaine d'autorite on-chain.

OWASP ASI07 Abus d'agent / d'outil : instruction injectee (document, page, autre agent) qui detourne l'outil de paiement. Pare par la detection d'injection.

MITRE ATLAS Prompt injection indirecte, evasion par encodage et obfuscation, manipulation d'agent.

Vecteurs HTML cache, PDF et mail piege, tool poisoning (MCP), confusion d'autorite, address poisoning, tresorerie migree, base64 / hex / url / ROT13, homoglyphes, unicode invisible, depassement de mandat, contrepartie frauduleuse.

La parade : verify_payment. Pipeline pur et explicable, avant la signature : sanitisation (HTML cache, unicode invisible, blobs encodes), puis 7 couches de signaux (contenu, mandat, autorite on-chain, contrepartie, transaction, outils, comportement), blocs durs, fusion Claude sur l'intention, score de confiance degressif, seuils `allow ≥ 70 · humain 30 a 70 · block < 30`. Le mandat est resolu cote serveur. Une adresse flaguee est refusee d'office la fois suivante.

Metriques atteintes (reproductibles)

100 %	**0 %**	**< 1 ms**	**20 / 20**
Detection	Faux positifs	Temps de detection	Bout-en-bout on-chain
23 attaques, redteam/run.py	52 controles legitimes	heuristiques ; ~3 s avec Claude	verdicts justes et mines

Limites connues

- Le jugement d'intention fin depend de Claude ; sans LLM, on ne devine jamais allow (plancher humain).
- La memoire des menaces est on-chain et durable, mais le jugement reste par transaction (pas encore de correlation multi-tx avancee).
- L'execution reelle du paiement exige un wallet agent autorise et approvisionne.
- Un adversaire peut inventer une strategie inedite : banc adaptatif teste (0 bypass), recalibrage continu, aucune triche.

SentinelL1 chainId 99999 · SEC **AuthorityRegistry** 0x7A7e…bcb6 **GuardedVault** 0xc7de…C7c0 **API** rpc.petroi.fr **Explorer** explorer.petroi.fr

Ville 3D city.petroi.fr